

Agent Sentinel

AI Agent Misbehaviour Detection & Recovery — a runtime safety layer for autonomous AI agents

Idea submission | Team: AgentGuard | Working prototype (controlled simulation) | Code: github.com/SHWE1530/agentguard-ai

1. Problem statement

Autonomous AI agents now hold real tool access: files, databases, permissions, infrastructure. They can act outside their intended task because of faulty reasoning, prompt injection, goal misalignment, excessive permissions or getting stuck in a loop. The dangerous failures are not crashes. They are **plausible-looking actions on the wrong resource**: reading a file the agent should not, escalating its own privileges, exporting data, dropping a table.

Existing defences each fail alone. A fixed allow-list misses behaviour nobody thought to enumerate. A model-only detector flags legitimate work (our measured false-positive rate is 5.5%, i.e. legitimate work blocked several times an hour) and can be talked around. Neither explains itself to a human, and neither helps once damage has landed.

2. Solution

Agent Sentinel wraps the agent in a layered safety envelope. Every action the agent attempts is intercepted *before* execution and run through one pipeline:

OBSERVE → DETECT → ASSESS RISK → EXPLAIN → ALLOW / MONITOR / APPROVE / BLOCK / STOP → RECOVER → VERIFY → AUDIT

Layer	Answers	How
ML behaviour detection	How unusual is this?	Isolation Forest on 16 behavioural features
Policy enforcement	Is this permitted?	Deterministic rules in an editable policy file
Risk scoring	How much does it matter?	Weighted fusion (0–100) of anomaly and consequence
Explanation	Why was I stopped?	Generated from the factors that actually fired
Human oversight	Should a person decide?	Blocking approval queue for high-consequence actions
Recovery + verification	Are we back to safe?	Rollback, re-inspect, report the truth

No layer is trusted alone — that is the central design claim. The model is an *input to* the decision, never the decision.

Demo (critical scenario): the agent checks server health (allowed), then attempts a permission change (blocked, privilege escalation), a data export (blocked, exfiltration) and DELETE_DATABASE (blocked pre-execution, agent stopped). The protected resource is still HEALTHY, an incident is opened, recovery runs, and the system reports *RECOVERY VERIFIED* only after re-inspecting every resource.

3. Technology

Area	Stack
Backend	Python 3.11, FastAPI, Pydantic v2, SQLAlchemy 2.0, SQLite, Uvicorn
ML	scikit-learn Isolation Forest (one-class novelty detection), pandas, numpy, joblib
Frontend	React 18, TypeScript, Vite, Tailwind CSS, Recharts
Realtime	WebSocket event stream with automatic reconnect
Quality	29 automated tests (pipeline, policy, recovery, audit, API, WebSocket); Docker support

Safety of the prototype itself: every dangerous action runs in a sandbox held in SQLite rows. Nothing touches a real file, database, service or host. The behavioural dataset is synthetic and generated locally; no credentials or sensitive data are used.

4. Innovation

- **Defence in depth for agent behaviour.** Learned anomaly detection and hard policy are fused, so novel misbehaviour is caught by the model and known-forbidden actions are never left to a probability.
- **Trained only on normal behaviour.** Unsupervised novelty detection means we do not need to enumerate every way an agent can fail.
- **Risk is not the anomaly score.** It weighs consequence (sensitivity, severity, privilege, task relevance) with weights in an editable file, so operators can tune without touching code.
- **Block is not halt.** A denied but reversible action lets the agent continue under suspicion so behaviour can be observed; only a critical irreversible attempt stops it. A repeat-offender rule pauses the agent for human review after repeated blocks.
- **Honest recovery.** Verification re-inspects the environment after rollback and reports failure if the world is still broken; it never assumes success.
- **Explainable and replayable.** Each decision shows factor weights, violated policies and a generated explanation; incidents can be replayed from an append-only audit trail.
- **Graceful degradation.** If the model is unavailable, a transparent heuristic keeps protection on and labels every score as such.

5. Impact

- **Safer autonomy.** Organisations can grant agents real tool access while keeping actions inside declared boundaries, which is the main blocker to production adoption.
- **Limits blast radius.** Harmful actions are stopped before execution, and recovery returns the environment to a verified known-good state.
- **Trust and accountability.** Human approval for high-risk actions plus a complete evidence chain supports compliance and post-incident review.
- **Fewer false alarms.** Combining model and policy avoids the operational cost of model-only blocking.
- **Broad applicability.** Relevant wherever agents operate: DevOps and SRE, customer-data workflows, finance operations, internal IT automation.

Measured on held-out synthetic data (2,536 records, 567 abnormal; reproducible with `python -m backend.ml.train_model`):

Precision	Recall	F1	False-positive rate	Mean anomaly: normal / abnormal
0.830	0.938	0.881	0.055	0.065 / 0.901

Limitations, stated plainly: results come from synthetic data and show that the pipeline works, not that it generalises to real agent telemetry. Future work: reasoning-trace analysis with LLMs, sequence models, multi-agent correlation, policy learning from operator decisions, and real IAM/Kubernetes integration.